

Third-party content in the delivered artefact

Everything that ships inside the scoped application, and its licence

THIRD-PARTY.md · rendered for review

The client's first and most emphatic requirement was licensing. This register covers everything that ships **inside the scoped application** — that is, everything present in `product/dist/COMMAND-Analytics-<version>-update-set.xml` and therefore everything that ends up on their instance.

Last verified 2026-09-08 against the source that produced update set 0.1.0.

Summary

third-party code in the runtime	none
third-party fonts in the runtime	2 families, 3 faces, all SIL OFL 1.1
runtime requests to any external host	none
copyright, source-available or non-commercial content	none

1. There is no third-party code in the runtime

There is no charting library. All 25 chart forms are drawn as SVG by `product/ui-scripts/cmd_render.js`, which is entirely first-party. ECharts was the default choice recorded in the engagement's own guidance and was not needed: drawing the marks directly removed a dependency, removed its licence question, and removed roughly 400 KB from the payload budget.

The server side is nine Script Includes, all first-party, using only the platform's own APIs (`GlideRecord`, `GlideRecordSecure`, `GlideAggregate`, `GlideDateTime`, `gs.*`).

Verification — the shipped browser assets contain no reference to any external host:

```
grep -nE 'https?://' product/ui-scripts/*.js product/ui-pages/*
# the only match is the SVG namespace URI, which is an XML identifier and not a
# request: cmd_render.js:33  var NS = 'http://www.w3.org/2000/svg';
```

This matters beyond licensing. A runtime request to an outside host would send every viewer's IP address to a third party on every dashboard load, which is a data-protection exposure rather than a licensing one. **Code and fonts travel in; data does not travel out.**

2. Fonts

Both families are embedded as base64 `woff2` data URIs inside the `cmd_fonts` UI Script, so the page makes no request for type.

FAMILY	FACES SHIPPED	LICENCE	RESERVED FONT NAME
Space Grotesk	weight 500, weight 600	SIL Open Font License 1.1	none declared
JetBrains Mono	weight 500	SIL Open Font License 1.1	none declared

Body text deliberately uses the platform's own sans stack rather than a third face, which is what keeps the type budget affordable — the three faces above are 39 KB gzipped in total.

Inter Tight is licensed and its licence text is checked in at `design/LICENSES/inter-tight-OFL.txt`, but it is **not shipped**: it appears in the design kit only. Listed here so the register matches the repository rather than only the artefact.

Why OFL 1.1 is satisfied

- **Embedding is permitted.** The OFL explicitly allows bundling the fonts in a larger work, commercially, with no royalty and no per-seat fee.
- **Subsetting is permitted.** The files are subsetting to basic Latin plus the typographic and geometric marks the product uses. A subset is a Modified Version under the OFL, which is allowed.
- **The family name may be kept.** Neither family declares a Reserved Font Name. That is the specific condition that makes a subset lawful *without* renaming it — had either declared one, the subset would have had to ship under a different name.
- **The licence travels with the fonts.** The OFL requires the licence text to accompany the fonts. It is reproduced in the header of the generated `cmd_fonts` UI Script, so it is present on the client's instance inside the application itself and not only in this repository.

Licence texts: `design/LICENSES/space-grotesk-OFL.txt`, `design/LICENSES/jetbrains-mono-OFL.txt`, `design/LICENSES/inter-tight-OFL.txt`.

3. Build-time tools, which are not delivered

These are used to produce the artefact and are not part of it. The constraint the engagement is under applies to the delivered runtime, not to the toolchain.

TOOL	LICENCE	ROLE
Python 3 standard library	PSF	<code>deploy.py</code> , <code>package.py</code> , the seeders
Node.js	MIT	runs the offline test suite
<code>fonttools</code>	MIT	subsets the woff2 files (<code>build_fonts.py</code>)

No third-party Python or Node package is imported by anything in `product/deploy/` or `product/tests/`: both use only their standard libraries.

4. Allowlist position

The engagement's permitted list is MIT, ISC, BSD-2/BSD-3, Apache-2.0, SIL OFL 1.1, CC0 and Unlicense; denied is GPL/LGPL/AGPL, SSPL, source-available, non-commercial, and anything commercial without a signed redistribution right on file.

Everything above is on the permitted list. **Nothing in the delivered artefact is denied, and nothing requires a commercial licence.** In particular Highcharts, which the engagement's guidance flagged as needing a paid — and for a distributed Store application, quote-only OEM — licence, is not used anywhere.

5. How to re-verify

```
# no external hosts in anything that reaches a browser
grep -nE 'https?://' product/ui-scripts/*.js product/ui-pages/*

# no third-party imports in the build tools
grep -rnE '^s*(import|from)s+' product/deploy/*.py product/tests/*.py \
  | grep -vE 'import
(argparse|hashlib|http|json|os|re|sys|time|urllib|collections|datetime|statistics|xml|pathlib)|from
pathlib|from snclient'

# what the artefact actually contains
python3 product/deploy/package.py --version 0.1.0
```